

Introduction a la Sécurité

Master 1: SI/SR UADB
Enseignant: Assane Gueye
Juin 24, 2024

Who we are?



Assane Gueye

ASSISTANT TEACHING PROFESSOR

Department(s): CMU-Africa

Email: assaneg@andrew.cmu.edu

Assane Gueye joined Carnegie Mellon University Africa on **August 1st, 2020**. Prior to joining CMU Africa, he was a faculty member at the **ICT Department at the University Alioune Diop of Bambey, Senegal**, where he also leads the research group “Technologies de l’Information et de la Communication pour le Développement” (TIC4Dev). Gueye also holds a guest researcher position with the **National Institute for Standards and Technology, Gaithersburg, Maryland, USA**. Assane is the **co-Director of the CyLab-Africa initiative and Director of the Upanzi Network project**.

Assane completed his **Ph.D. in electrical engineering and computer sciences from UC Berkeley** in March 2011. He holds a **Master’s degree in communication systems engineering from Ecole Polytechnique Fédérale de Lausanne, Switzerland**.

His research focuses in two main areas: **performance evaluation and security of large-scale communication systems, Digital Public Goods, and information and communication technologies for development (ICT4D)**. Assane is a Fellow of the Next Einstein Forum (Class of 2016). In 2019 he was nominated as a member of the European Alliance for Innovation (EAI) inaugural Fellow Class.

Who we are?

Junias Bonou

Lab Engineer, Upanzi Network Project



Junias Bonou is a seasoned cybersecurity professional with a diverse background in government, consulting, and academia. Bonou joins CMU-Africa as a lab engineer working with the Upanzi Network project. He brings extensive experience in digital forensics, incident response, building defensive security infrastructures, conducting security assessments, developing innovative solutions for digital public goods. Bonou is an alumnus of Carnegie Mellon University and holds a master of science degree in information technology specializing in cybersecurity.

EMAIL

jbonou@andrew.cmu.edu

Who we are?

U P A N Z I

DIGITAL PUBLIC INFRASTRUCTURE

NETWORK

Just one Rule

Mutual Respect!

My name is

~~Dr.
Prof
Monsieur~~

ASSANE Gueye

Your name is

~~Monsieur~~

???

Oui...on peut se tutoyer!

Course Materials

- Slides
- Printouts (Articles, Book Chapters, etc...)
- Recommended Books
 - [*Security in Computing, 4th ed.*](#) (Charles P. Pfleeger, Shari Lawrence Pfleeger; [Prentice Hall](#), 2007)
 - [*Security Engineering, 2nd ed.*](#) (Ross Anderson; Wiley, 2008)
 - *Practical Intrusion Analysis: Prevention and Detection for the Twenty-First Century*, [Ryan Trost](#)

I will look for French translation!

Grading

- Quizzes (xxx %)
 - Summary & Critics of weekly readings
- Lab Work (yyy %)
- Final Exam (www %)
 - Theory
 - Practice

Plan du cours

- Plan Général
 - Introduction: Sécurité données et applications
 - L'être humain: le maillon faible
 - La facilite d'utilisation des solutions
 - L'ingénierie sociale
 - Sécurité des programmes/applications et des protocoles
 - Sécurité des réseaux
 - Sécurité du Web
 - Cryptographie et Solutions cryptographique
 - Sécurité et nouvelles technologies
 - Politiques de Sécurité

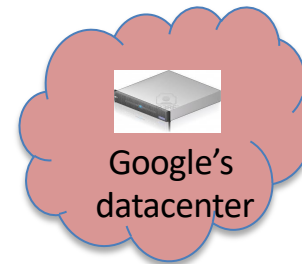
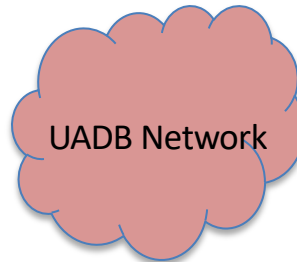
A note on ethics!

We will be discussing **attacks**, some of them quite nasty, and also powerful eavesdropping technology. None of this is in any way an invitation to undertake these in any fashion other than with **informed consent** of all involved parties. If in any context you are uncertain about where to draw the line, come talk with me first.

Remember your Networking Course?

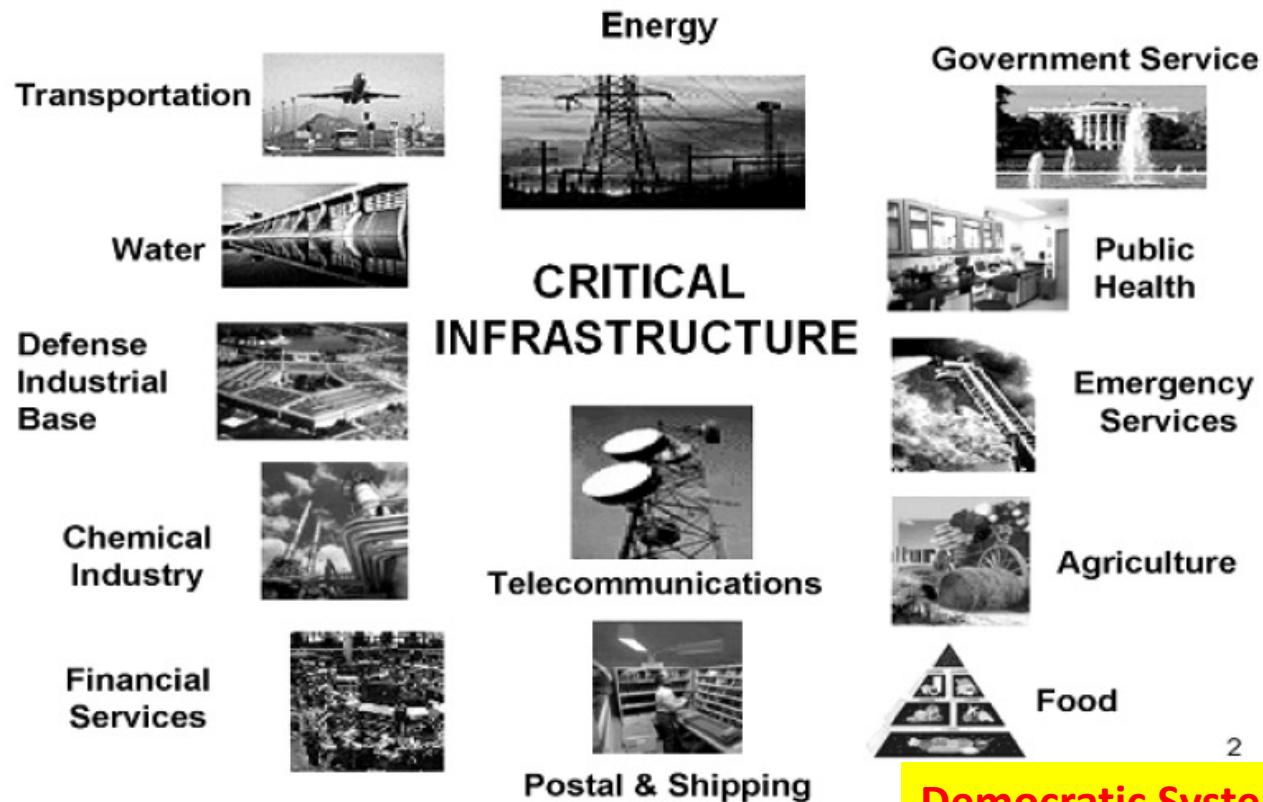
Describing a “very” common activity

Walk through the steps required to download
www.google.com/index.html from your “machine”???



Pourquoi la Sécurité?

The **national and economic security** of the nations depends on the **reliable functioning** of



Democratic System

To **communicate**
To **produce, transport and deliver energy**
To **move people and goods**

To **do business**
To **entertain and stay in touch**
...

A revolutionized world... with a **Fifth Dimension!**

Then...



Now!





FBI Director James B. Comey Jr.

November 18, 2015: I believe **that we stand in the middle of the greatest transformation in human relations in human history.** And this is a change that affects all of the FBI's work, **because cyber is not a thing, it's a way—it's a vector.** Because **we have connected all of our lives to the Internet;** because it's where we bank; because it's where we have social lives— if I had one, I'm sure it would be on the Internet. It's where our children play, it's where our health care is, it's where our financial information is, it's where our critical infrastructure is. **It's where life is.** And that will become more and more true as the "**Internet of things**" becomes a feature of all of our lives, and our sneakers talk to our refrigerator and our car talks to our heating system. **All of our lives are there**, and so **those who would do us harm**—who would steal our money, hurt our kids, damage our infrastructure, look to attack our nation—**that's where they come.** It is a vector change unlike any we've ever seen before.

Unfortunately, they have also **exposed us to many new risks** and have made our society **more than ever vulnerable** to

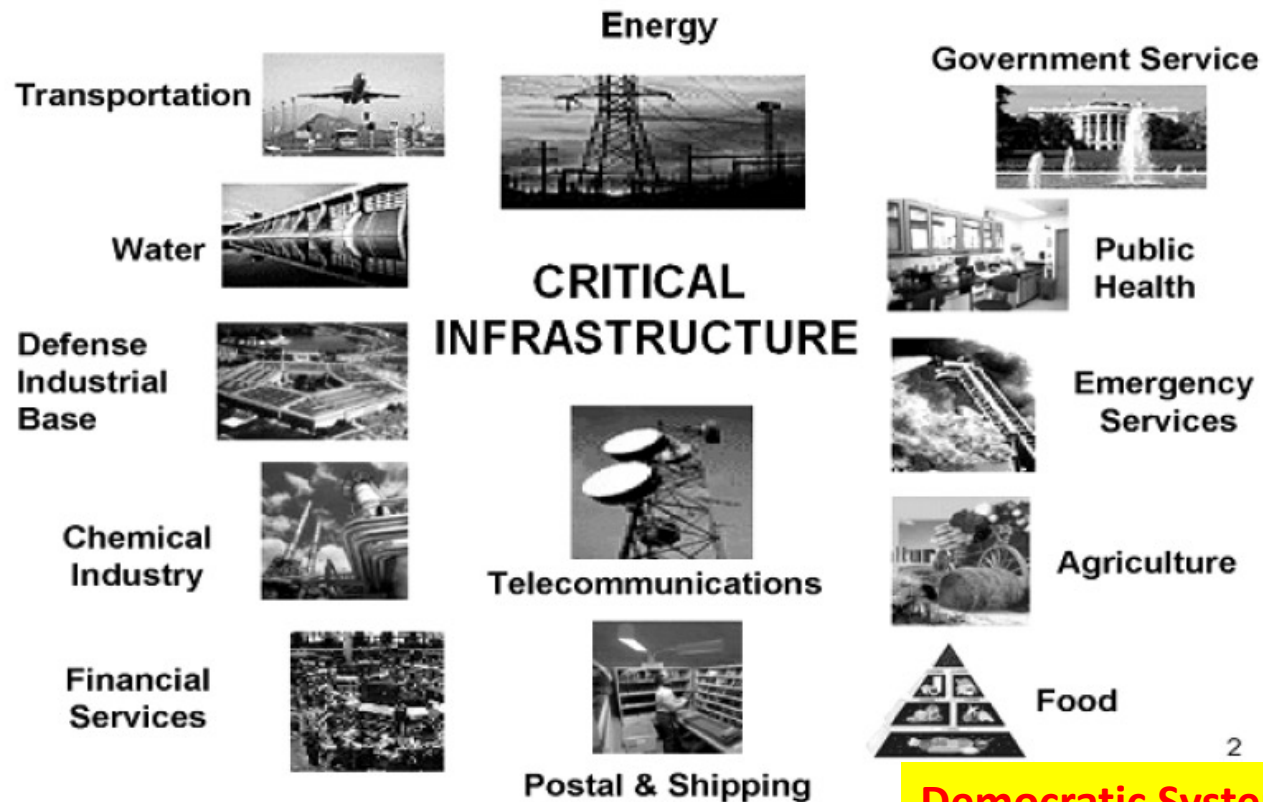
accidental failures,

but also...

malicious attacks.



The **national and economic security** of the nations depends on the **reliable functioning** of



Democratic System

To **communicate**
To **produce, transport and deliver energy**
To **move people and goods**

To **do business**
To **entertain and stay in touch**
...

Cyber-attack hits Malawi's immigration service

22 February 2024

By Peter Jegwa in Lilongwe & Basillioh Rukanga, BBC News

Share 



Malawi's President Lazarus Chakwera said the cyber-attack was a serious breach of national security

Malawi's government has suspended the issuing of passports following a cyber-attack on the immigration service's computer network.

Your email address

Subscribe

MYBROADBAND
TRUSTED IN TECH

f t in RSS What's Next

NEWS

PRESS OFFICE

FORUM

INDUSTRY NEWS

FEATURES

COMPANY HUB

SPEED TEST

Q

“Cybersecurity incident” takes down Lesotho’s entire payments system

Jan Vermeulen 14 December 2023



Your email address

Subscribe

Interbank and international payments routed through Lesotho are offline following a cyberattack impacting its central bank

FOLLOW US



Your email address

Subscribe

POLL

Which is your go-to online retailer for tech products?

☐ Takealot

☐ Amazon

☐ Bob Shop

☐ Incredible

☐ Hi-Fi Corp

☐ Makro

☐ Game

☐ Loot

Your email address

Subscribe

NEWS

PRESS OFFICE

FORUM

INDUSTRY NEWS

FEATURES

COMPANY HUB

SPEED TEST



Good news about South African water and sewage control systems following global hack

Jan Vermeulen 11 December 2023



Your email address

Subscribe

The Department of Water and Sanitation (DWS) has told MyBroadband that it does not use the programmable controllers exploited in a recent

FOLLOW US



Your email address

Subscribe

POLL

Which is your go-to online retailer for tech products?

☐ Takealot

☐ Amazon

☐ Bob Shop

☐ Incredible

☐ Hi-Fi Corp

☐ Makro

☐ Game

☐ Loot

☐ G.W.

Les hackers APT20 ont contourné la sécurité à double authentification

Des pirates informatiques liés au gouvernement chinois ont réussi à passer au-delà de ce paramètre de sécurité normalement inviolable.

Par Valentin Cimino - @ciminix
Publié le 24 décembre 2019 à 08h51



Crédit : Picture Alliance / Getty Images



RSA SecurID SD600



RSA SecurID SID700



RSA SecurID SD200



RSA SecurID SID800



RSA SecurID SD520



BlackBerry with
RSA SecurID software token

December 2019

Les principales cibles du groupe étaient des entités gouvernementales et des fournisseurs de services dans des domaines tels que l'aviation, la santé, la finance, l'assurance, l'énergie, ainsi que des niches comme les paris et les sociétés de serrures.

Malgré une forte activité ces deux dernières années, Fox-IT explique que le groupe a réussi, dans l'ensemble, « à rester en dehors des radars ». Pour ça, ils ont utilisé des outils officiels, installés auparavant sur les machines piratées, plutôt que d'utiliser un malware de leur propre construction qui aurait pu être détecté par les logiciels de sécurité.

If you did not build it, you cannot secure it!

Le mode opératoire reste incertain, mais l'équipe de Fox-IT a sa théorie. Elle pense que APT20 a réussi à voler un jeton logiciel RSA SecurID depuis un système piraté, et l'a ensuite utilisé sur ses appareils pour générer des codes à validité unique et ainsi outrepasser la sécurité à deux facteurs à volonté.

Security flaws in a popular smart home hub let hackers unlock front doors

Zack Whittaker @zackwhittaker / 10:00 am EDT • July 2, 2019



Image Credits: Chase Dardaman, Jason Wheeler

<https://techcrunch.com/2019/07/02/smart-home-hub-flaws-unlock-doors/>

The researchers found they **could extract the hub's private SSH key for "root" — the user account with the highest level of access — from the memory card on the device.** Anyone with the private key could access a device without needing a password, said Wheeler. They later discovered that **the private SSH key was hardcoded in every hub sold to customers** — putting at risk every home with the same hub installed.

Using that private key, the researchers downloaded a file from the device containing scrambled passwords used to access the hub. They found that the smart hub **uses a "pass-the-hash" authentication system**, which doesn't require knowing the user's plaintext password, only the scrambled version. By taking the scrambled password and passing it to the smart hub, the researchers could trick the device into thinking they were the homeowner.

Piratage : La plateforme d'échange de crypto-monnaie Upbit perd 48,5 millions de dollars

1 mois ago

La plateforme d'échange de crypto-monnaie sud-coréenne Upbit a informé ses clients qu'une cyberattaque avait entraîné le vol de 48,5 millions de dollars de crypto-monnaie. Les Ethereum ont été volés dans le portefeuille principal de l'entreprise.

Mercredi, la plateforme Upbit a suspendu son service de dépôt et de retrait, affirmant dans un communiqué que 342 000 ETH (Ethereum) avaient été volés et que la crypto-monnaie avait été transférée vers une adresse inconnue. Le montant total du piratage est d'environ 48,5 millions de dollars [d'après le communiqué](#).



Homeland
Security



National Cyber Awareness System:

AA18-337A: SamSam Ransomware

12/03/2018 11:18 AM EST

Original release date: December 03, 2018

Summary

The Department of Homeland Security (DHS) National Cybersecurity and Communications Integration Center (NCCIC) and the Federal Bureau of Investigation (FBI) are issuing this activity alert to inform computer network defenders about SamSam ransomware, also known as MSIL/Samas.A. Specifically, this product shares analysis of vulnerabilities that cyber actors exploited to deploy this ransomware. In addition, this report provides recommendations for prevention and mitigation.

The SamSam actors targeted multiple industries, including some within critical infrastructure.

The actors exploit Windows servers to gain persistent access to a victim's network and infect all reachable hosts. FBI analysis of victims' machines indicates that cyber actors use Remote Desktop Protocol (RDP) to gain persistent access to victims' networks. Typically, actors either use brute force attacks or stolen login credentials. Detecting RDP intrusions can be challenging because the malware enters through an approved access point.

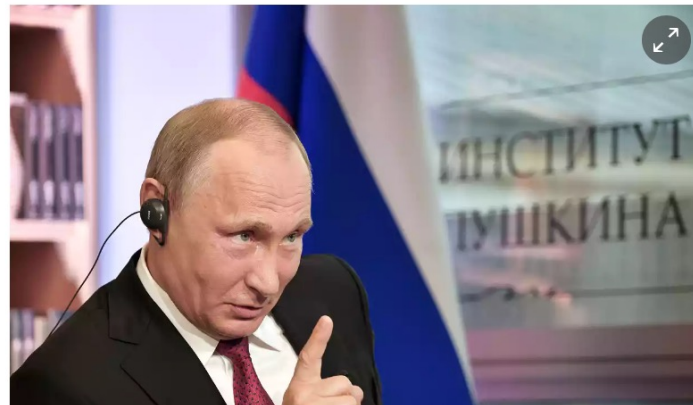
After gaining access to a particular network, the SamSam actors escalate privileges for administrator rights, drop malware onto the server, and run an executable file, all without victims' action or authorization. While many ransomware campaigns rely on a victim completing an action, such as opening an email or visiting a compromised website, RDP allows cyber actors to infect victims with minimal detection.

The democratic system!



Russian hacking went far beyond US election, digital hitlist reveals

- Hackers targeted Ukrainian officers, US defense contractors and many others
- News comes as US weighs charges against Russian government officials



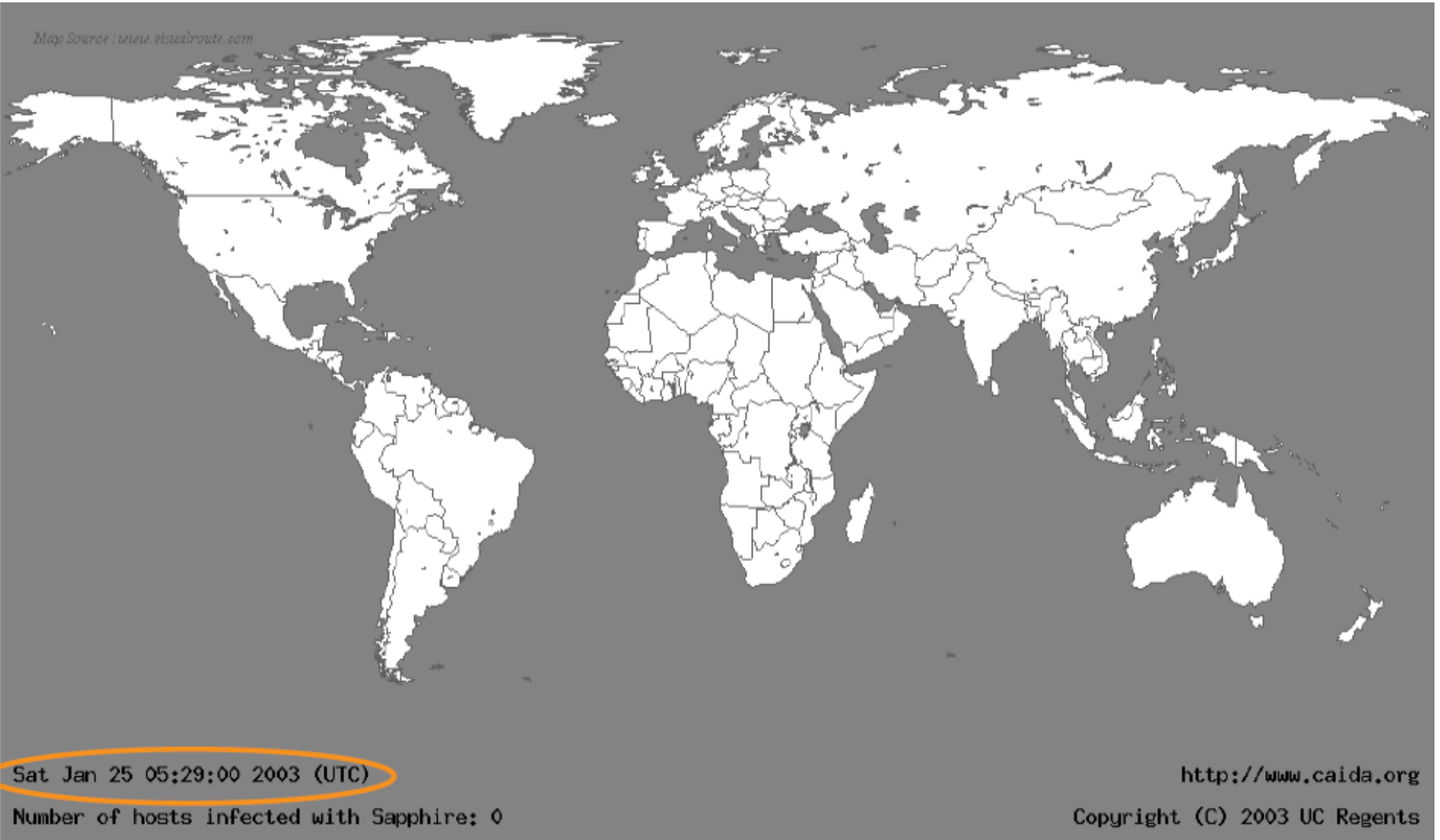
Happening on a daily basis

<https://www.bbc.com/news/topics/cp3mvdpdp1r2t>

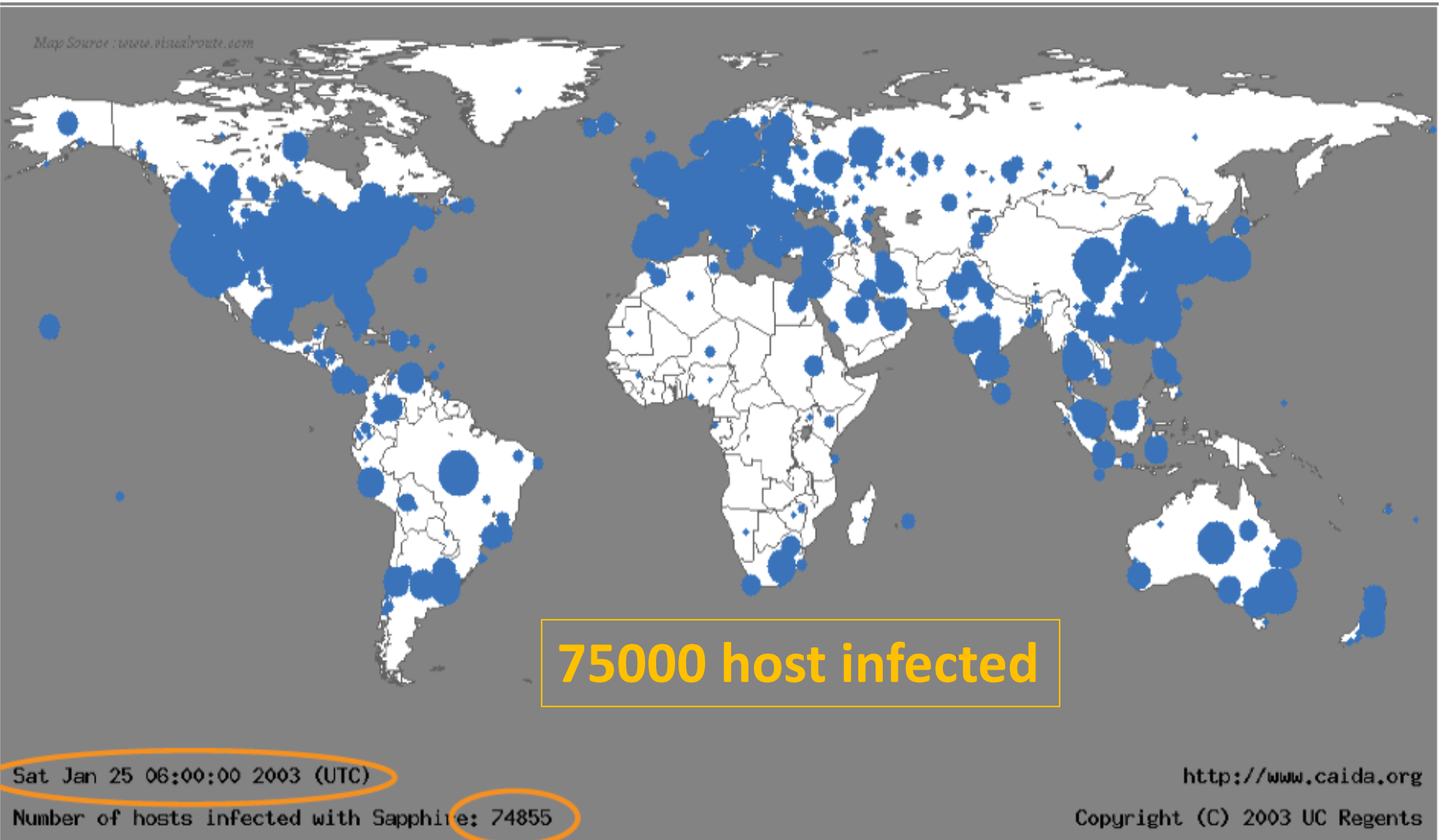
Very fast...and high volume!

Life just before Slammer worm attack

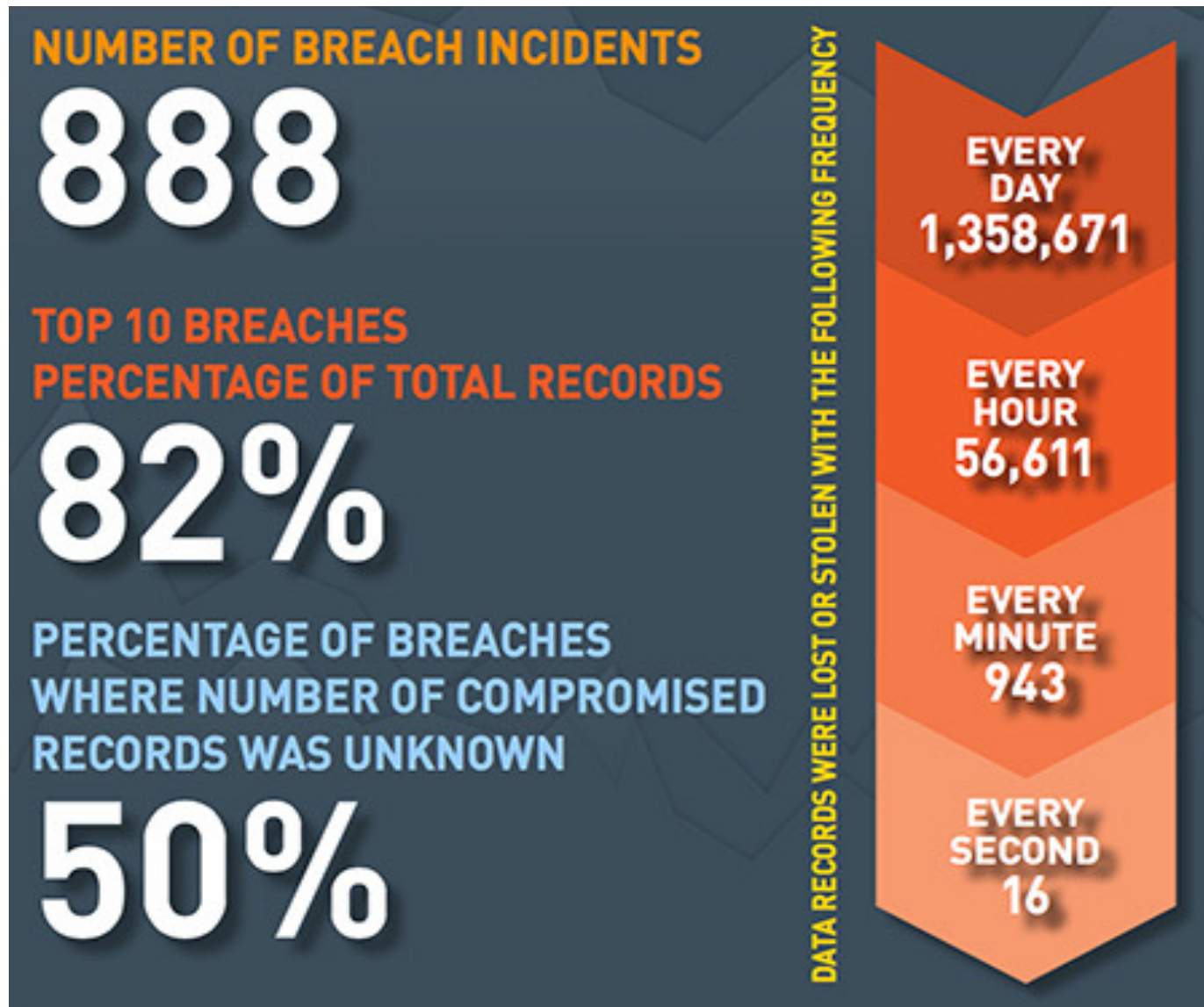
Map Source : www.visualroute.com



30 minutes later!



Recap - 2015



2015 Identity Theft Stats

DATA BREACHES

DATA RECORDS LOST OR STOLEN IN 2015

707,509,815

ONLY 4% of breaches were "Secure Breaches" where encryption was used and the stolen data was rendered useless.

1,938,383

records lost or stolen
every day



80,766

records
every hour



1,346

records
every minute



22

records
every second



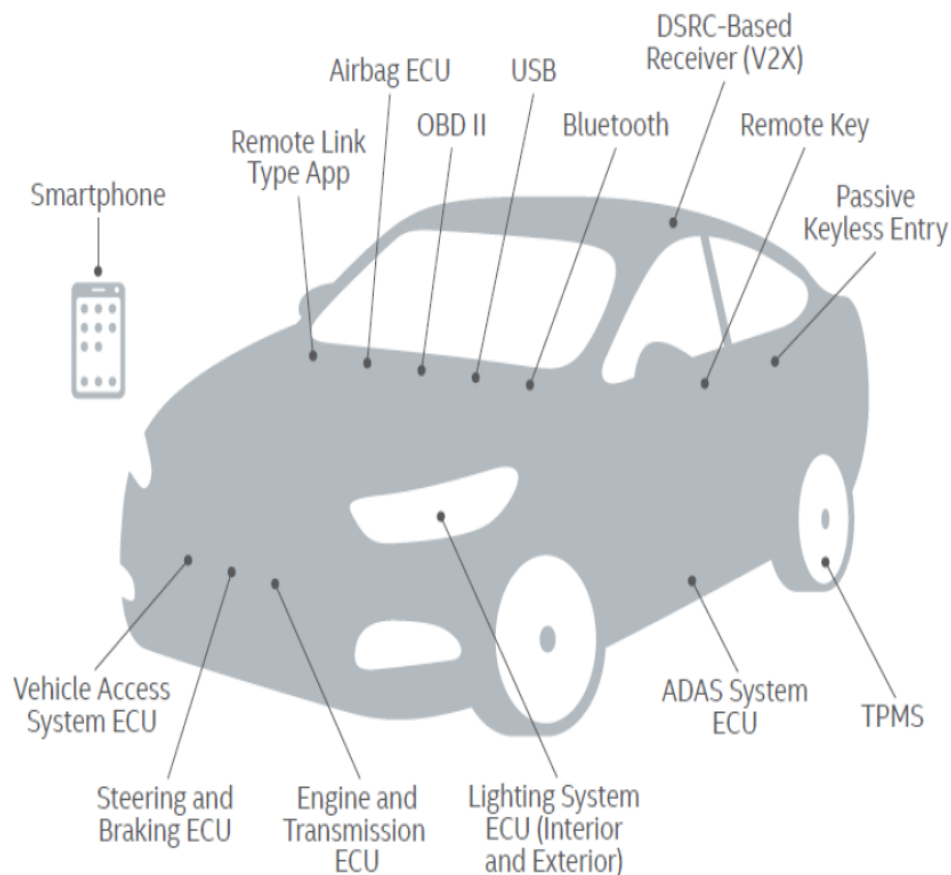
How does the future look like?

McAfee Labs 2016 Threat Predictions

Automobiles

Attacks on automobiles will increase sharply in 2016 due to the rapid increase in connected automobile hardware built without foundational security principles.

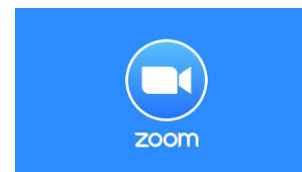
Automobile Attack Surfaces



McAfee Labs 2016 Threats Predictions

Cloud services

Cybercriminals, competitors, vigilante justice seekers, and nation-states will increasingly target cloud services platforms to exploit companies and steal confidential data.



McAfee Labs 2016 Threats Predictions

Payment systems

Alternate payment methods like bitcoin, PayPal, and Venmo have greatly multiplied the payment system attack surface. Cyber criminals will increasingly focus on attacks that lead to the theft and sale of alternate payment method login credentials.



McAfee Labs 2016 Threats Predictions

Wearables

Wearables will be a prime target for cyber criminals because they collect personal data and they are relatively insecure back doors into smartphones.

Wearables Attack Surfaces



- Operating system kernel
- Networking software/WiFi
- User interface
- Memory
- Local files and storage system
- Access control/security software



- Cloud virtual machine and control apps
- Web app
- Memory
- Local files and storage system
- Access control/security software

Internet of Things

City/Infrastructure



Home



Toys



Platform



Automotive



Lifestyle/Entertainment



User Interface



Tags/Trackers



Healthcare



Fitness



Smartwatch/jewelry



Agriculture



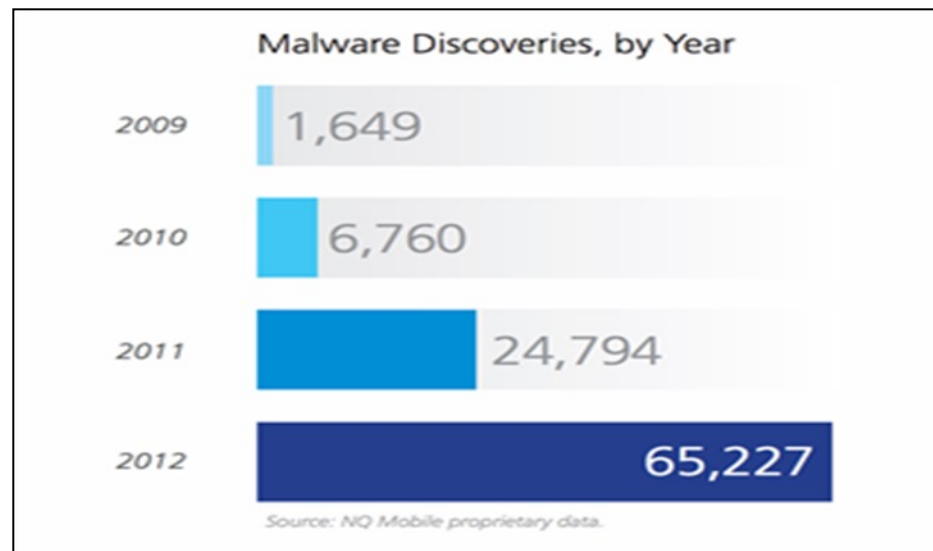
Cible Mobile – Tablettes / Smartphones

Logiciels contrefaits et infectés (Dec 2012)

La quantité de maliciels à destination des terminaux mobiles équipés d'Android a plus que doublé en un an, d'après un récent rapport d'une société de sécurité mobile.

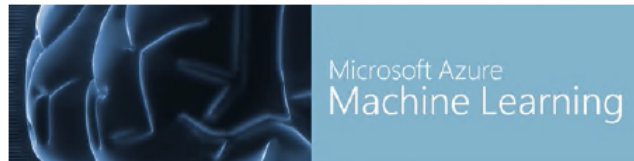
Le nombre de maliciels pour la plateforme Android est passé de 25000 en 2011 à plus de 65000 en 2012.

Le rapport annuel, publié par la société de sécurité mobile NQ Mobile, a aussi estimé que 33 millions de terminaux Android ont été infectés en 2012, ayant augmenté de presque 11 millions en un an — une augmentation de plus 200 pourcent.



Examples: ML-as-a-service

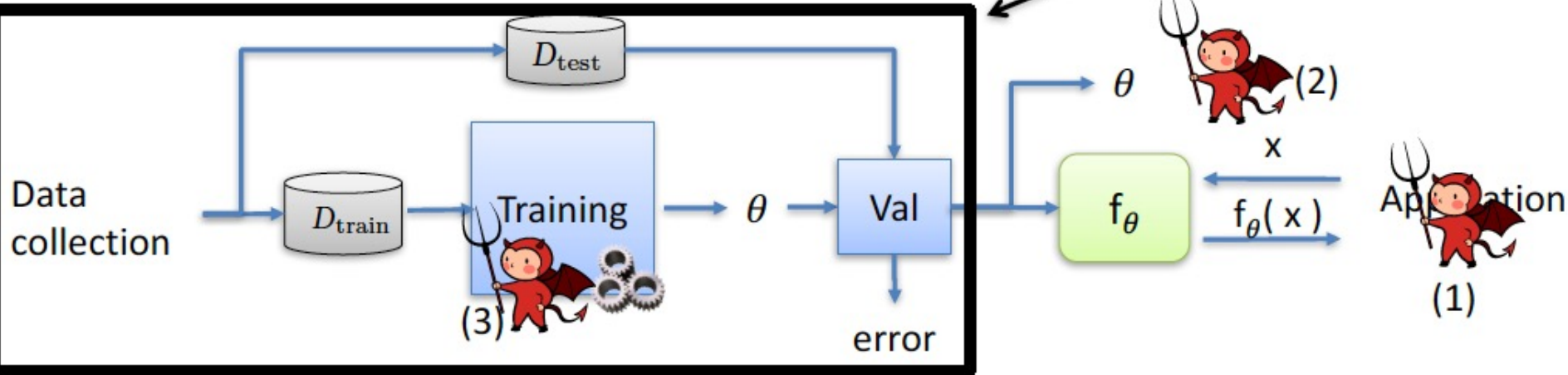
Amazon Machine Learning



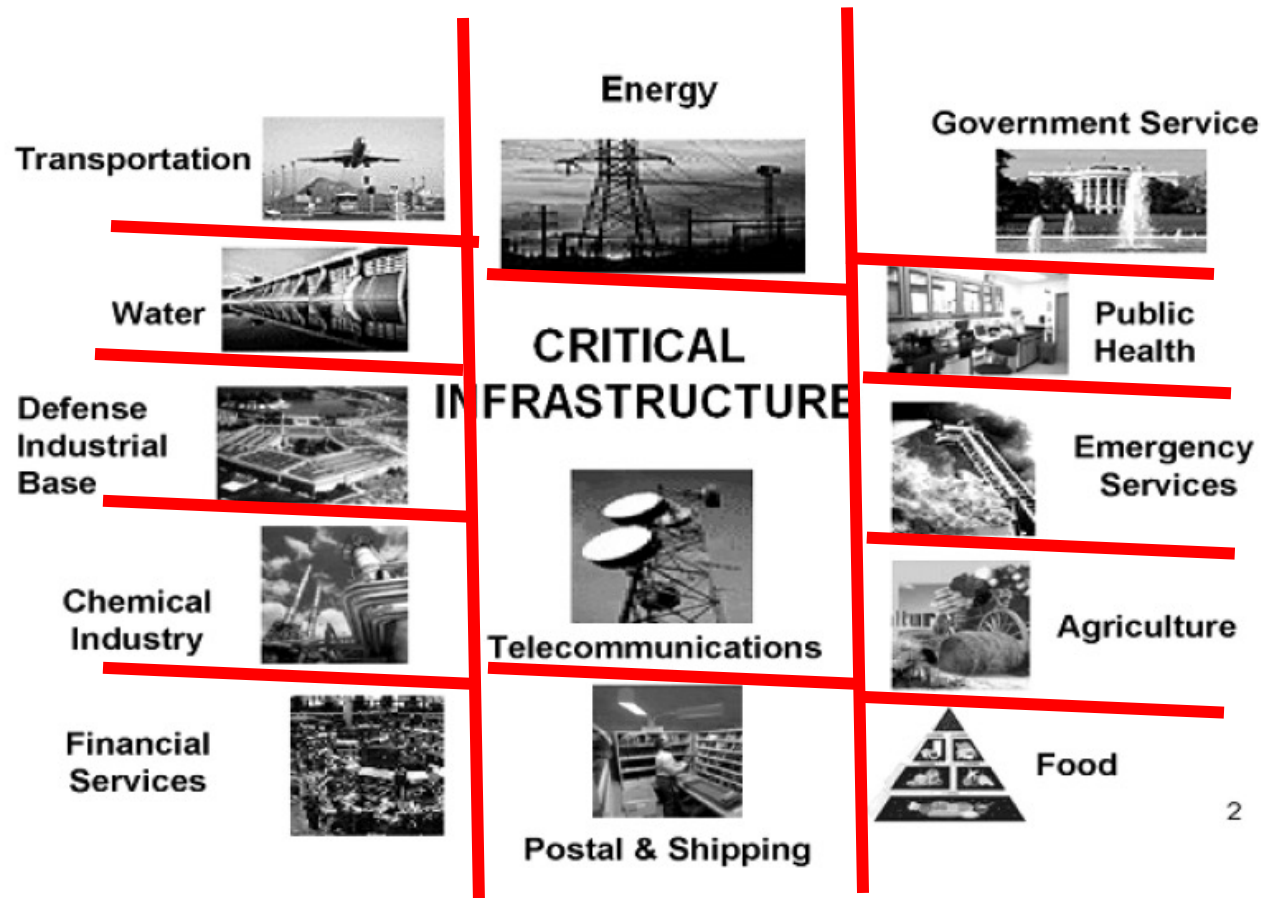
Service	Model types / training algorithms
Amazon	Logistic regression
Google	Logistic regression, (convolutional / recurrent) neural networks, ...
Microsoft	Logistic regression, decision trees, neural networks, SVM
BigML	Logistic regression, decision trees
Algorithmia	Custom training algorithms (from third party developers)

New Threat Models in ML

Isolated, secured environment



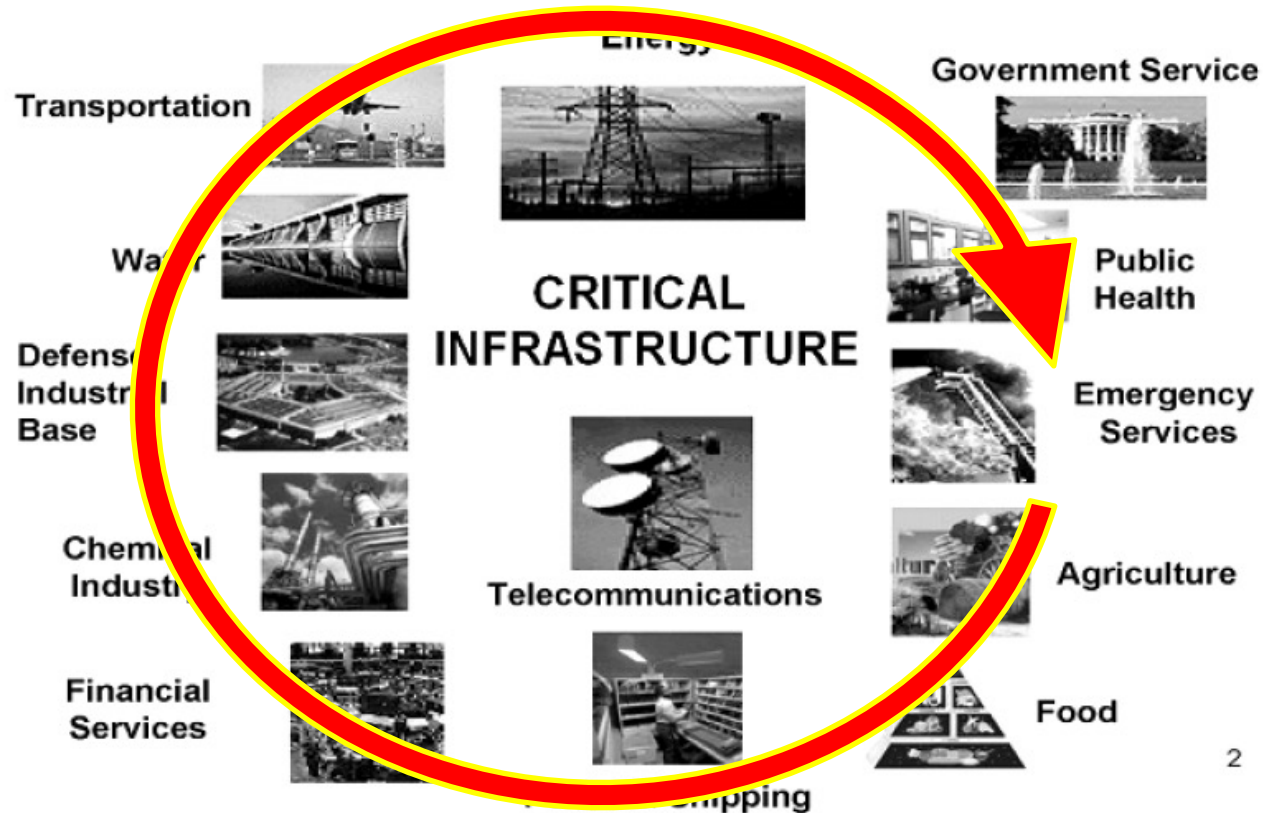
The **national and economic security** of the nations depends on the **reliable functioning** of



To **communicate**
To **produce, transport and deliver energy**
To **move people and goods**

To **do business**
To **entertain and stay in touch**
...

The **national and economic security** of the nations depends on the **reliable functioning** of



To **communicate**
To **produce, transport and deliver energy**
To **move people and goods**

To **do business**
To **entertain and stay in touch**
...

A revolutionized world... Interconnected and ...in Danger

CYBERSECURITY

Ransomware Attack Targeting Microsoft Windows Hits Spanish Telco Giant Telefonica

Reuters

May 12, 2017



Spain said on Friday a large number of companies, including telecommunications giant Telefonica, had been infected with malicious software known as "ransomware" which locks up computers and demands ransoms.

The hacking was carried out as hospitals and doctors' surgeries in England were forced to turn away patients and cancel appointments on Friday after a ransomware attack crippled some computer systems in the state-run health service.

Portugal Telecom was also hit by a cyber attack but no services were impacted, a spokeswoman for the company said.

2017
WannaCry!

Healthcare
Transport
Telecom

....



<https://www.yahoo.com/gma/researcher-accidentally-stops>

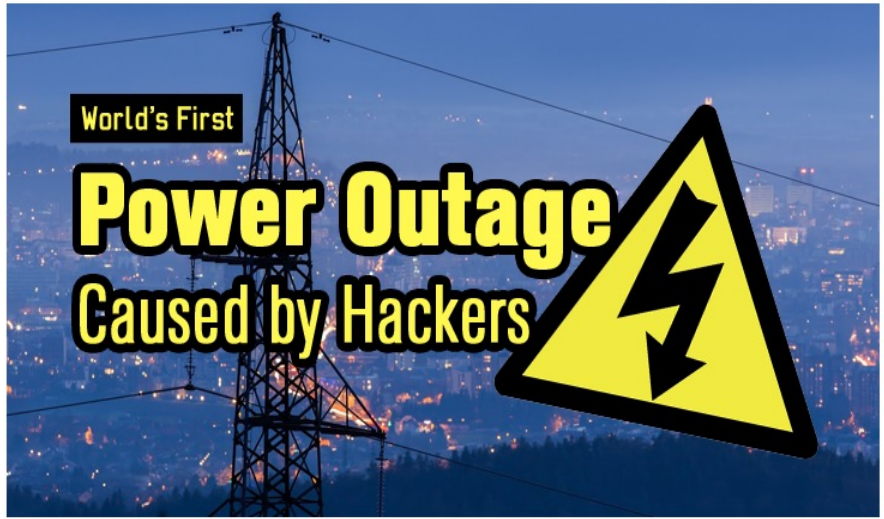
**Ukraine 2015 power outage caused
by coordinated hack attack**

 **The Hacker News**™
Security in a serious way

Hackers Cause World's First Power Outage with Malware

 Tuesday, January 05, 2016  Swati Khandelwal

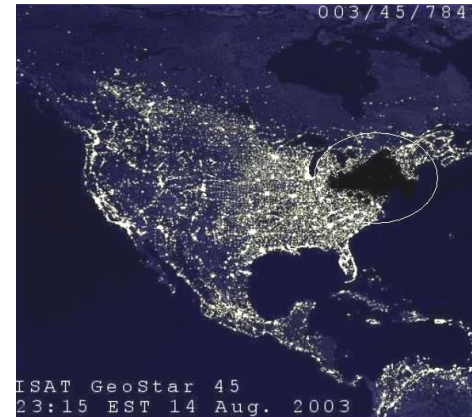
 323  Share 2268  Tweet 596  Share 74  Share 3261



Blackout of 2003 in the U.S. and Canada

11 deaths

\$6 billions of economic damage



Another Anecdote



What did happen...

YouTube 2008 outage

2 hours of outage

Pakistan Telecom disconnected

Financial crisis of 2008

Bush 2...nightmare!



Tendances des cyberattaques

Tendances des cyberattaques

- **Augmentation du nombre d'adversaires** (états et cybercriminels) dotés de capacités informatiques.
- **Le “Cybercrime-as-a-service” augmentera probablement**, abaissant les barrières d'entrée dans le monde de la cybercriminalité.
- **La sophistication** des cyber adversaires va s'améliorer, rendant la détection et les interventions plus difficiles.
- **Le harponnage/hameçonnage** va continuer à être populaire parmi les adversaires, et l'utilisation de la technique dite des points d'eau va s'amplifier.
- **Les rançongiciels** vont continuer d'augmenter leur notoriété.
- L'augmentation du nombre d'adversaires doté de **capacités destructives** et potentiellement le nombre d'incidents contenant des éléments destructifs.
- L'augmentation du nombre de **graffitis numériques**, tel que le défaçage de sites et le détournement de réseaux sociaux, qui sont conçus pour arriver en tête d'affiche.

Projections diverses

- Les chercheurs en sécurité informatique et les **attaquants vont de plus en plus se concentrer sur la découverte de failles dans les systèmes de contrôle industriels**, mettant ces systèmes en plus grand danger. [1]
- **Sécuriser la chaîne d'approvisionnement continue à être une tâche ardue**, en se basant sur des efforts pluridisciplinaires afin de fonctionner. [1]
- **Les pirates** utilisent des maliciels de mieux en mieux élaborés qui témoignent **d'une ingénierie informatique sophistiquée** et empreinte de professionnalisme. [2]
- Certaines **campagnes telles que Dragonfly, Waterbug et Turla ont infiltré des systèmes industriels**, des ambassades et d'autres cibles sensibles.[2]
- Le nombre de campagnes de harponnage a augmenté de 8% en 2014; malgré la baisse du nombre d'attaques journalières les **pirates deviennent plus patients**, se terrant dans l'attente de la réalisation d'attaques plus subtiles, aidés par la reconnaissance à long terme de leurs actions. [2]

Réf:

1. Rapport sur les cyber menaces émergentes en 2016, Institut de Technologie de Géorgie (2015)
2. Rapport de sécurité informatique d'internet, Symantec, Volume 20, Avril 2015